

Checklist de Sécurité - StatDirm

Utilisez cette checklist avant de déployer l'application en production.

Authentification

- ☐ Fichier `.htpasswd` créé avec `htpasswd`
- ☐ Authentification HTTP Basic activée dans `nginx.conf`
- ☐ Mot de passe fort configuré (minimum 12 caractères)
- ☐ Authentification application (`AuthGuard`) testée
- ☐ Session expire après fermeture du navigateur
- ☐ Test d'accès sans authentification (doit être bloqué)

HTTPS/TLS

- ☐ Certificat SSL/TLS obtenu (Let's Encrypt recommandé)
- ☐ Configuration HTTPS décommentée dans `nginx.conf`
- ☐ Redirection HTTP → HTTPS activée
- ☐ HSTS (Strict-Transport-Security) activé
- ☐ Certificat valide et non expiré
- ☐ Renouvellement automatique configuré (certbot)

Headers de Sécurité

- ☐ X-Frame-Options: DENY
- ☐ X-Content-Type-Options: nosniff
- ☐ X-XSS-Protection activé
- ☐ Content-Security-Policy configurée
- ☐ Referrer-Policy configurée
- ☐ Permissions-Policy configurée
- ☐

Headers vérifiés avec `curl -I`

Protection des Fichiers

- ☐ Accès aux fichiers `.json` bloqué (403)
- ☐ Accès aux fichiers `.env` bloqué
- ☐ Accès aux fichiers cachés (`.git` , etc.) bloqué
- ☐ Test d'accès direct aux fichiers sensibles effectué

Rate Limiting

- ☐ Rate limiting configuré dans Nginx
- ☐ Limite de requêtes testée
- ☐ Limite de connexions testée
- ☐ Logs de rate limiting vérifiés

Docker

- ☐ Dockerfile optimisé (multi-stage build)
- ☐ Pas de secrets dans les images Docker
- ☐ Volumes montés en lecture seule (`:ro`)
- ☐ Healthcheck configuré
- ☐ Limites de ressources configurées
- ☐ Conteneur ne s'exécute pas en root (si possible)

Firewall

- ☐ Ports nécessaires uniquement ouverts (80, 443)
- ☐ Port SSH (22) sécurisé (clés SSH recommandées)
- ☐ Ports inutiles fermés
- ☐ Règles de firewall testées



Configuration

- ☐ Fichier `.env` créé à partir de `.env.example`
- ☐ Variables d'environnement sensibles configurées
- ☐ `.env` ajouté à `.gitignore`
- ☐ `agents.json` ajouté à `.gitignore`
- ☐ Fichiers sensibles non commités dans Git



Monitoring et Logs

- ☐ Logs Nginx activés et vérifiés
- ☐ Logs Docker configurés
- ☐ Monitoring des tentatives d'accès non autorisées
- ☐ Alertes configurées (si applicable)



Sauvegardes

- ☐ Stratégie de sauvegarde définie
- ☐ Script de sauvegarde créé et testé
- ☐ Plan de restauration documenté
- ☐ Sauvegardes automatisées (cron)



Tests de Sécurité

- ☐ Test d'authentification avec mauvais mot de passe
- ☐ Test d'accès aux fichiers sensibles (403 attendu)
- ☐ Test de rate limiting (429 attendu après limite)
- ☐ Test des headers de sécurité
- ☐ Test HTTPS (certificat valide)
- ☐ Test de redirection HTTP → HTTPS

Documentation

- ☐ `SECURITE.md` lu et compris
- ☐ `DEPLOIEMENT_SECURISE.md` suivi
- ☐ Procédures documentées
- ☐ Contacts d'urgence identifiés

Conformité RGPD

- ☐ Base légale identifiée pour le traitement
- ☐ Personnes concernées informées
- ☐ Mesures techniques et organisationnelles en place
- ☐ Droit d'accès et de rectification prévu
- ☐ Durée de conservation définie

Post-Déploiement

- ☐ Application accessible via HTTPS
- ☐ Authentification fonctionnelle
- ☐ Toutes les fonctionnalités testées
- ☐ Performance acceptable
- ☐ Monitoring actif

Date de vérification : _____

Vérifié par : _____

Prochaine révision : _____